

İTÜ

Security in Financial Information Systems

Access Control

Dr. Şerif Bahtiyar
bahtiyars@itu.edu.tr

1

Before Starting

Yaşanan Erişim Sorunu Hakkında Bilgilendirme:



Dijital kanallarımızdaki hizmetlere erişimin yavaşlatılması ya da engellenmesine yönelik, **DDOS** (Distributed Denial of Service, Dağıtık Hizmet Engelleme) olarak adlandırılan bir atak mevcuttur.

https://www.garantibbva.com.tr/tr/garanti_hakkinda/garantiden_haberler/2019/ekim/dijital-kanallarimizdaki-hizmetlere-erisim-sorunu

Dr. Şerif Bahtiyar

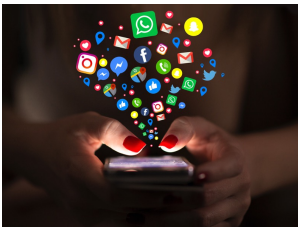
Access Control

2

2

Before Starting

Stalkerware: The software that spies on your partner



Amy says it all started when her husband seemed to know intimate **details** about her **friends**.

<https://www.bbc.com/news/technology-50166147>

Dr. Şerif Bahtiyar

Access Control

3

3

Outline

- Definition, Functions, Policies, and Requirements
- Access Control Models
- Network Access Control
- Extensible Authentication Protocol

Dr. Şerif Bahtiyar

Access Control

4

4

Definition of Access Control

- **Access Control**: The **prevention** of **unauthorized use** of a resource, including the prevention of use of a resource in an unauthorized manner.



- **Central element** of computer security
- We consider **user groups**, not networked environment.
- All **systems need access control**.
- Access control mechanisms **mediate** between a **user** and **system resources**.

Dr. Şerif Bahtiyar

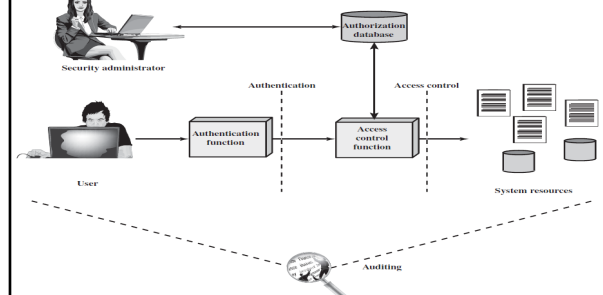
Access Control

5

5

Access Control Functions

Authentication, Authorization, Audit



Dr. Şerif Bahtiyar

Access Control

6

6

Access Control Policies

Discretionary Access Control (DAC)

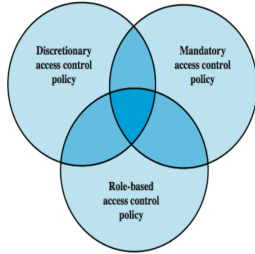
- Access based on the **identity** of the requestor and on access **rules**
- An entity may **enable** another entity to access resources

Mandatory Access Control (MAC)

- Access based on comparing **security labels**
- An entity cannot **enable** another entity to access resources

Role-Based Access Control (RBAC)

- Access **based** on **roles of users**



Dr. Şerif Bahtiyar

Access Control

7

7

Access Control Policies

Attribute-Based Access Control (ABAC)

Access **based** on **attributes of the user**, the **resource to be accessed**, and **current environmental conditions**

In Application Security

- Authorization policies and attributes are defined in a technology neutral way.
- Policies for one API can be reused for another API
- Common **application benefit from ABAC** (Wikipedia)
 - Content management systems
 - Home grown applications
 - WEB APPLICATIONS**

Dr. Şerif Bahtiyar

Access Control

8

8

Access Control Requirements

- Reliable input (authentication)
- Fine and coarse specifications
- Least privilege
- Separation of duty
- Open and closed policies
- Policy combinations, conflict resolution
- Administrative policies
- Dual control

Dr. Şerif Bahtiyar

Access Control

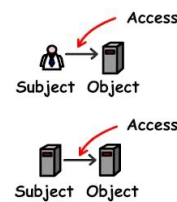
9

9

Elements of Access Control

Subject: is an **entity** capable of **accessing objects**.

- A **process** representing **user** or **application**
- Often have **three classes**: owner, group, world



Dr. Şerif Bahtiyar

Access Control

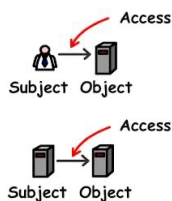
10

10

Elements of Access Control

Object: a **resource** to which access is controlled.

- Files, records, directories, programs, ...
- Number and type depend on environment



Dr. Şerif Bahtiyar

Access Control

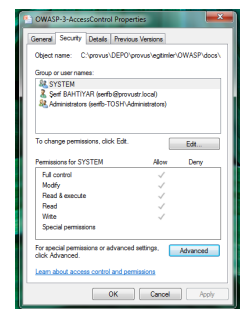
11

11

Elements of Access Control

Access right: describes the way in which a **subject** may **access** an **object**.

- Read, write, execute, delete, search, create



Dr. Şerif Bahtiyar

Access Control

12

12

Discretionary Access Control (DAC)

Generally provided with **access control matrix**

- lists **subjects** in one dimension (**rows**)
- lists **objects** in the other dimension (**columns**)
- each entry **specifies access rights** of the specified subject to object
- is often **sparse**

		OBJECTS			
		File 1	File 2	File 3	File 4
SUBJECTS	User A	Own Read Write		Own Read Write	
	User B	Read	Own Read Write	Write	Read
	User C	Read Write	Read		Own Read Write

Dr. Şerif Bahtiyar

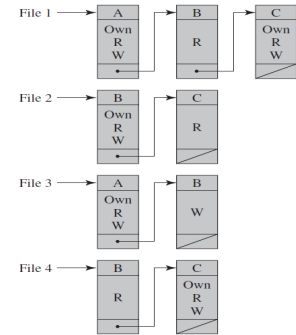
Access Control

13

Discretionary Access Control (DAC)

Access control list (ACL)

- Matrix **decomposition** by **columns**
- **Convenient** from **subject** side
- **Inconvenient** for determining **access rights** to a specific **user**



Dr. Şerif Bahtiyar

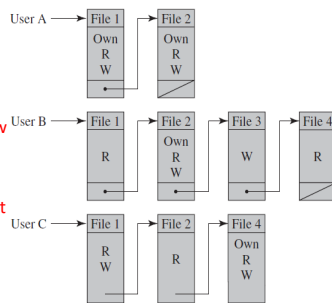
Access Control

14

Discretionary Access Control (DAC)

Capability tickets

- Matrix **decomposition** by **row**
- **Appropriate** for use in **distributed** environment
- **Convenient** and **inconvenient** aspects are **opposite** of **ACL**



Dr. Şerif Bahtiyar

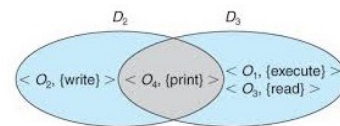
Access Control

15

Discretionary Access Control (DAC)

Protection Domain

- Set of objects with **associated rights**
- In access matrix view, **each row** is a **protection domain**
 - But **not necessarily** just a user
 - May be a **limited** subset of user's **access rights**
 - **Applied** to a more **restricted process**
- May be **static** or **dynamic**



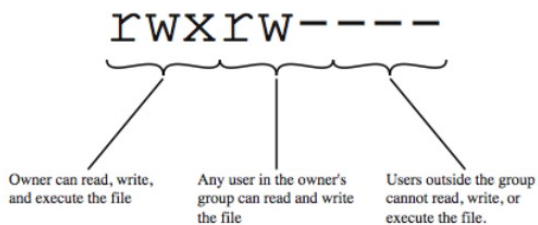
Dr. Şerif Bahtiyar

Access Control

16

Discretionary Access Control (DAC)

UNIX File Access Control



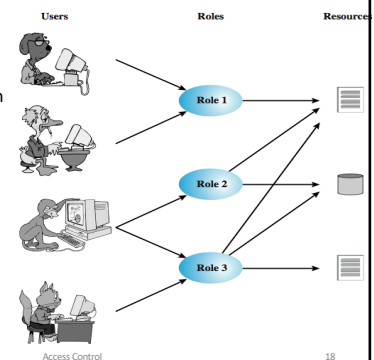
Dr. Şerif Bahtiyar

Access Control

17

Role-Based Access Control (RBAC)

- Based on the **roles** that users assume in a system **rather than the user's identity**.
- Define a role as a **job function** within an **organization**.



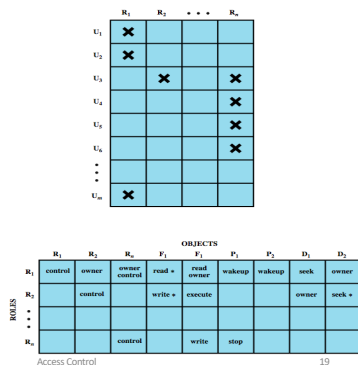
Dr. Şerif Bahtiyar

Access Control

18

Role-Based Access Control (RBAC)

- Assign access rights to roles instead of individual users.
- Users are assigned to different roles, either statically or dynamically, according to their responsibilities.



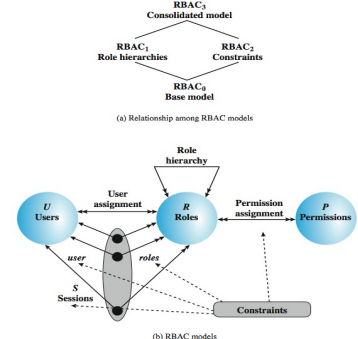
Dr. Şerif Bahtiyar

Access Control

19

Role-Based Access Control (RBAC)

The many-to-many relationships between users and roles and between roles and permissions provide a flexibility and granularity of assignment not found in conventional DAC schemes.



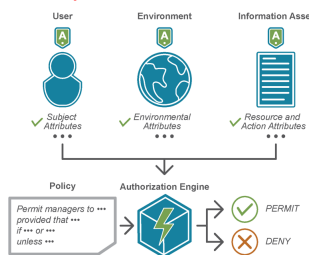
Dr. Şerif Bahtiyar

Access Control

20

Attribute-Based Access Control (ABAC)

ABAC can define authorizations that express conditions on properties of the resource and the subject.



The strength of ABAC is its flexibility and expressive power.

Dr. Şerif Bahtiyar

Access Control

21

Attribute-Based Access Control (ABAC)

Key Elements of ABAC

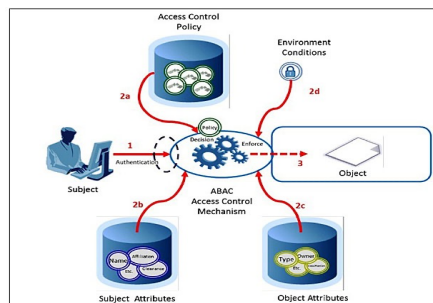
- Attributes define specific aspects of subject, object, environment conditions, and requested operations. Types of attributes:
 - Subject attributes
 - Object attributes
 - Environment attributes
- Policy is set of rules and relationships that govern allowable behavior within an organization.
- Architecture applies to policies that enforce access control.

Dr. Şerif Bahtiyar

Access Control

22

Attribute-Based Access Control (ABAC)



- Subject Requests Access to Object
- Access Control Mechanism Assesses a) Rules, b) Subject Attributes, c) Object Attributes, and d) Environment Conditions to Determine Authorization
- Subject is Given Access to Object if Authorized and Denied Access if Not authorized

Dr. Şerif Bahtiyar

Access Control

23

Other Access Control Models

- History Based Access Control (HBAC)
History of activities are used to determine access rights.
- Identity Based Access Control (IBAC)
Accesses are determined according to an individual.
- Organization Based Access Control (OrBAC)
Security policies are determined independently from implementations.
- Rule Based Access Control (RAC)
Preferred for specific contexts.
- ...

Dr. Şerif Bahtiyar

Access Control

24

Network Access Control

- **Network Access Control (NAC)** is an umbrella term for managing access to a network.



- **NAC authenticates users** logging into **network** and determines **what data** they can access and **actions** they can perform.
- **NAC** examines the **health** of user's computer or mobile device.

Dr. Şerif Bahtiyar

Access Control

25

25

Network Access Control

Elements of NAC

- **Access requestor (AR):** **node** attempting to **access** network and may be any device that is managed by the NAC system, including workstations, servers, printers, cameras, and other IP-enabled devices. ARs are called **supplicants** or **clients**.
- **Policy server:** **determines what** access should be **granted**. The policy server often relies on backend systems, including antivirus, patch management, or a user directory, to help determine the host's condition.
- **Network access server (NAS):** an **access control point** for users in **remote locations** connecting to an enterprise's internal network, called **media gateway**, **remote access server (RAS)**, or **policy server**.

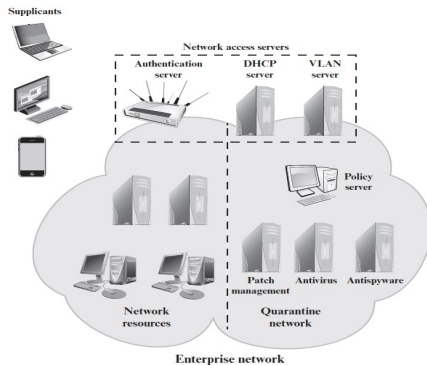
Dr. Şerif Bahtiyar

Access Control

26

26

Network Access Control



Dr. Şerif Bahtiyar

Access Control

27

27

Network Access Control

- The **first step** is generally to **authenticate AR**.
- **Authentication** may be performed by the **NAS**, or the NAS may **mediate** the authentication process.
- **Policy server** or **supporting server** will **perform checks** on AR to determine if it is **permitted** interactive remote access **connectivity**.
- Once an **AR** has been **authenticated** and **cleared** for a certain level of access to the enterprise network, the NAS can **enable AR to interact** with **resources** in the enterprise network.

Dr. Şerif Bahtiyar

Access Control

28

28

Network Access Control

Network Access Enforcement Methods are the **actions** that are applied to **ARs** to **regulate access** to the enterprise **network**.

- **IEEE 802.1X:** This is a **link layer protocol** that enforces **authorization** before a **port** is assigned an **IP address**. IEEE 802.1X makes **use of Extensible Authentication Protocol** for the authentication process.
- **Virtual local area networks (VLANs):** enterprise network is **segmented logically** into number of **virtual LANs**. **NAC decides** to which of network's **VLANs** it will direct an AR.
- **Firewall:** **Provides** form of NAC by allowing or denying network traffic between enterprise host and external user.
- **DHCP management:** **Dynamic Host Configuration Protocol (DHCP)** is an Internet protocol that **enables dynamic allocation of IP addresses** to **hosts**.

Dr. Şerif Bahtiyar

Access Control

29

29

Extensible Authentication Protocol

Extensible Authentication Protocol (EAP) acts as a **framework** for **network access** and authentication protocols.

- Defined in RFC 3784
- **Provides** a set of protocol **messages** that can encapsulate **various authentication** methods to be used **between client** and **authentication server**.
- **Operate** over a **variety of network** and **link level** facilities.
- **Supports multiple authentication** methods -> called **extensible**
- **Provides** a generic **transport service** for the **exchange of authentication** information between a **client** system and an **authentication server**.

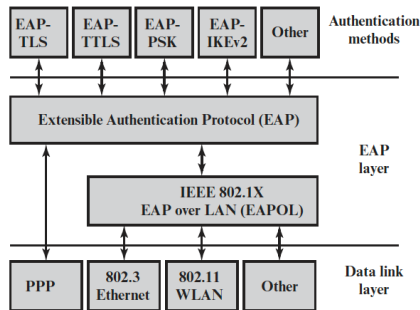
Dr. Şerif Bahtiyar

Access Control

30

30

Extensible Authentication Protocol



Dr. Şerif Bahtiyar

Access Control

31

31

Extensible Authentication Protocol

EAP Components:

- **EAP peer:** Client computer that is attempting to access a network.
- **EAP authenticator:** An access point or NAS that requires EAP authentication prior to granting access to a network.
- **Authentication server:** Server that
 - negotiates use of specific EAP method with an EAP peer,
 - validates EAP peer's credentials,
 - authorizes access to the network. Typically, the authentication server is a Remote Authentication Dial-In User Service (RADIUS) server.

Dr. Şerif Bahtiyar

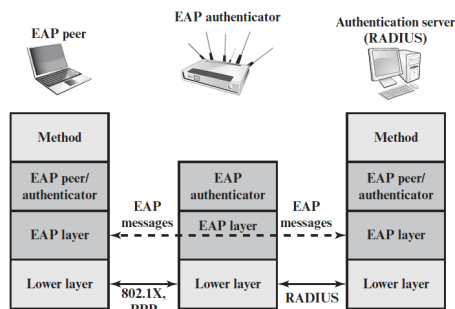
Access Control

32

32

Extensible Authentication Protocol

EAP Protocol Exchanges



Dr. Şerif Bahtiyar

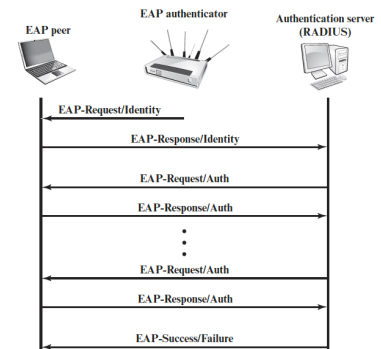
Access Control

33

33

Extensible Authentication Protocol

EAP Message Flow



Dr. Şerif Bahtiyar

Access Control

34

34

Summary

- Access control functions
- Principles, policies, requirements
- Elements: subject, object, access rights
- DAC, MAC, RBAC, ABAC
- Network Access Control
- Extensible Authentication Protocol

Dr. Şerif Bahtiyar

Access Control

35

35

Questions?

Dr. Şerif Bahtiyar

Access Control

36

36